

Research on Security for Software Updates of Intelligent Connected Vehicles Based on Post-Quantum Cryptography

Wanli Zhao

Dept. of Data Platform

Tianjin CATARC Data Co., Ltd.

Tianjin, China

zhaowanli@catarc.ac.cn

Wang Zhang

Dept. of Data Platform

Tianjin CATARC Data Co., Ltd.

Tianjin, China

zhangwang2021@catarc.ac.cn

Lian Zhao*

Central Academy

Shanghai Electric Group Co., Ltd.

Shanghai, China

*Zhaolian1998@163.com

Zhengyang Yu

Dept. of Data Platform

Tianjin CATARC Data Co., Ltd.

Tianjin, China

yuzhengyang@catarc.ac.cn

Abstract—This paper addresses the security challenges of intelligent connected vehicle software updates in the quantum computing era by proposing a hybrid cryptography scheme (PQ/T) that combines post-quantum cryptography (PQC) with classical cryptography. Our solution extends X.509 digital certificates to incorporate PQC algorithms while maintaining compatibility with existing PKI infrastructure. The proposed dual-signature approach enables seamless migration to quantum-resistant security without disrupting current over-the-air (OTA) update systems. Experimental results demonstrate that PQ/T effectively safeguards software update packages against quantum threats while preserving the performance of conventional TLS protocols. This work provides a practical transition pathway for automotive cybersecurity in the post-quantum era.

Keywords—post-quantum cryptography; OTA; hybrid cryptography; digital certificate

I. INTRODUCTION

To ensure the security of automotive OTA software upgrades, the industry primarily relies on classical public-key cryptography algorithms such as RSA, ECC, and SM2. These algorithms play a critical role in encryption, TLS authentication, and digital signatures, balancing security and efficiency in protecting vehicular communication and data transmission. However, with the advancement of quantum computing, classical public-key cryptography (PKC) like RSA and ECC face severe security threats.

Quantum computers, leveraging Shor's algorithm [1], can reduce the complexity of breaking RSA to polynomial time. Similarly, Grover's algorithm [2] can reduce the computational complexity of the elliptic curve discrete logarithm problem (ECDLP) to its square root. Consequently, PKC is vulnerable to quantum attacks.

To address these threats, post-quantum cryptography (PQC) was first proposed by Michael A. O. Neilly in 1991 and has since evolved into a specialized branch of cryptography aimed at countering quantum computing risks. On August 13, 2024, the U.S. National Institute of Standards and Technology (NIST) officially released the first three global PQC standards, ML-KEM (Module-Lattice-Based Key-Encapsulation Mechanism Standard) [3], ML-DSA (Module-Lattice-Based Digital

Signature Standard) [4], SLH-DSA (Stateless Hash-Based Digital Signature Standard) [5]. Industrial standardization efforts have accelerated PQC adoption in automotive systems. NXP Semiconductors and NIST jointly released deployment guidelines for post-quantum PKI in 2025, providing concrete implementation frameworks for OTA security upgrades [6].

Securing intelligent connected vehicle software upgrades with PQC requires not only preparing for a full-scale quantum era but also addressing the current widespread use of classical PKC in OTA systems. Thus, this study explores a transitional approach that maintains compatibility with existing PKI while integrating PQC for future-proof security.

II. CRYPTOGRAPHY SECURITY REQUIREMENTS FOR AUTOMOTIVE SOFTWARE UPDATES

Regulatory frameworks such as UN/WP.29 UN Regulation No. 156 on Software Updates and Software Update Management Systems mandate that vehicle manufacturers ensure the security and integrity of updates to prevent tampering (Sections 7.1.3.1 and 7.2.1.1). Similarly, China's national standard General Technical Requirements for Automotive Software Updates requires manufacturers to securely store software update records for at least 10 years after a model's discontinuation (Section 4.1.2). Additional standards, such as Technical Requirements for Automotive Cybersecurity, specify that OTA systems must:

- Protect the trusted root, bootloader, and firmware from tampering (Section 7.3.1).
- Authenticate vehicles and OTA servers (Section 7.3.2),
- Verify the authenticity and integrity of downloaded update packages (Section 7.3.2.2).

Thus, automotive software updates must address four fundamental security requirements: integrity, confidentiality, authenticity, and non-repudiation to comply with legal and regulatory standards.

III. THE ROLE OF CRYPTOGRAPHY IN SOFTWARE UPDATES

Modern cryptography has evolved into a mature system encompassing both symmetric and asymmetric cryptography

mechanisms, effectively addressing the four fundamental security requirements of information: integrity, confidentiality, authenticity, and non-repudiation. Through the application of various encryption algorithms and protocols, these core security requirements are fulfilled during information transmission and storage.

In practical engineering implementations, Public Key Infrastructure (PKI) is established to provide cryptography applications and protection for automotive software upgrades. Specifically:

- Certificate Authority (CA) issue digital certificates to vehicles for identity authentication, enabling secure TLS channels and mutual authentication.
- Code-signing certificates, leveraging private keys, are used to digitally sign software update packages, ensuring their integrity and origin authenticity.

IV. POST-QUANTUM SECURITY FOR AUTOMOTIVE SOFTWARE UPDATES

Post-Quantum Cryptography (PQC) can be primarily categorized into four types based on its mathematical principles [7]: lattice-based PQC systems, code-based PQC systems, hash-based PQC systems, and multivariate polynomial-based PQC systems. Currently, three standard algorithms have been standardized by NIST.

ML-KEM is a post-quantum secure key encapsulation mechanism designed to protect the security of encrypted communications against potential quantum computing threats. It is derived from the CRYSTALS-KYBER algorithm, employs the Module Learning with Errors (MLWE) problem—an extension of the LWE problem in lattice theory. The scheme incorporates the Number Theoretic Transform (NTT) for computational efficiency optimization. The LWE problem concerns solving systems of linear equations under noise influence, formally defined as:

$R_q = \mathbb{Z}_q[X]/(X^n + 1)$, Randomly sample Secret vector $s \in R_q^k$, uniformly random matrix $a_i \in U(R_q^k)$, $Compute = a_i^T s + e_i \in R_q$, output m pairs of samples $(a_i, b_i) \in R_q^k \times R_q$.

For cryptographic schemes based on the MLWE problem, the condition $m = k$ must be satisfied to ensure private key security. Thus, when arranged row-wise, the m MLWE samples can be expressed as: $(A, b) \in R_q^{k \times k} \times R_q^k$, Where: $b = AS + e$.

ML-DSA is a lattice-based digital signature algorithm, with its core being the extended Module Learning With Errors problem from the LWE problem in lattice theory, and it is optimized by the Number Theoretic Transform to improve efficiency.

SLH-DSA is a post-quantum digital signature algorithm based on hash functions. SLH-DSA is mainly constructed based on the SPHINCS+ algorithm [8], combining:

Few-Time Signatures (FTS): HyperTree (HSS) and eXtended Merkle Signature Scheme (XMSS).

Hash Functions: SHAKE-256 or SHA-256 as the underlying primitive.

Merkle Trees: For authentication path compression.

Recent hardware implementations demonstrate significant optimizations for PQC algorithms in automotive ECUs. Perazzo et al. showed that ML-DSA signature verification latency can be reduced by 42% through SHA-3 hardware acceleration, making lattice-based cryptography feasible for resource-constrained vehicle controllers [9]. This breakthrough addresses critical performance barriers for real-time OTA verification.

For V2X authentication, Xu et al. proposed a blockchain-based linkable ring signature scheme combining SLH-DSA with zero-knowledge proofs [10]. This approach achieves quantum-safe anonymous authentication while maintaining 38% lower communication overhead than traditional PKI, enabling secure software updates in multi-party vehicular networks.

In the context of automotive software upgrade security, it is possible to directly employ post-quantum cryptography to replace classical cryptography for achieving identity authentication and code signing in Over-The-Air (OTA) updates. However, such a direct substitution poses a significant engineering challenge. Specifically, an all-at-once switch would necessitate a complete overhaul of the security infrastructure and applications, thereby precluding a smooth transition.

To address this issue, during the transition from classical algorithms to post-quantum algorithms, the gradual replacement of the existing public key infrastructure using a hybrid approach that combines post-quantum and classical public-key cryptography is a more viable option. This approach facilitates a seamless migration from an ecosystem that solely implements and utilizes classical algorithms to one that exclusively employs post-quantum algorithms.

The Cybersecurity and Infrastructure Security Agency (CISA) of the United States has published "Quantum-Ready: The Migration to Post-Quantum Cryptography", and the European Union Agency for Cybersecurity (ENISA) has released the "POST-QUANTUM CRYPTOGRAPHY — Integration study". Both documents highlight the hybrid post-quantum and classical cryptography algorithms as one of the essential technical pathways for migration.

A. PQ/T Hybrid Cryptography

The Post-quantum Traditional (PQ/T) hybrid cryptography [11] is a cryptographic approach that combines one or more Post-Quantum Cryptography (PQC) algorithms with one or more classical Public Key Cryptography (PKC) algorithms, where all algorithms must belong to the same category. For instance, combining a PQC signature algorithm with a classical PKC signature algorithm results in a PQ/T hybrid signature.

Compared to methods employing a single algorithm, the PQ/T hybrid algorithm approach achieves compatibility between pre-quantum and post-quantum algorithms within the same security application, thereby providing adaptive security protection under different computational conditions. When applied to Public Key Infrastructure (PKI), it ensures the

concurrent use of non-quantum-safe systems and systems that have been upgraded to quantum-safe status without requiring significant modifications to the existing PKI. Overall, this method offers distinct advantages in terms of smooth system and application migration, switching costs, and interoperability.

B. PQ/T Hybrid Certificate Design

The equations are an exception to the prescribed specifications of this template. You will need to determine whether or not your equation should be typed using either the Times New Roman or the Symbol font (please no other font). To create multileveled equations, it may be necessary to treat the equation as a graphic and insert it into the text after your paper is styled. The Hybrid Certificate is a standard X.509 digital certificate that integrates classical public-key algorithms with post-quantum public-key cryptographic algorithms. Its primary feature is the ability to support both classical and post-quantum cryptography signature algorithms without altering the existing X.509 certificate format.

Based on the combination of PKC (Public Key Cryptography) and PQC (Post-Quantum Cryptography) public keys and digital signatures in digital certificates, hybrid certificates can be designed in the following five ways:

- **Hybrid Concatenated Certificate:** This uses a specific algorithm identifier OID to represent the combination of classical and post-quantum algorithms, with keys and signatures following the standard ASN.1 syntax rules. The advantage is that it does not change the ASN.1 structure of the digital certificate.
- **Hybrid Bound Certificate:** This is constructed by binding separate classical and post-quantum certificates. The post-quantum certificate contains an extension that links it to the classical certificate; the classical certificate may also contain a similar extension linking to the post-quantum certificate, providing an authenticated pointer to the other certificate. The advantage is that the two systems can operate independently
- **Hybrid Composite Certificate:** This is an improvement over the previous HYBRID CONCATENATED format, using ASN.1 encoding to separate the classical and post-quantum algorithm objects [12].
- **Hybrid Using Extensions Certificate (Catalyst):** This stores post-quantum objects in X.509 extension fields. Apart from the extensions, this certificate is identical to a classical X.509 certificate. Therefore, assuming that it treats unknown non-critical extensions as opaque data, unmodified certificate tools can parse and validate it. In principle, this format is upward compatible.
- **Hybrid Delta Extensions Certificate (Chameleon):** This encodes the differences between two certificates in a single extension. One certificate is the "base" or outer certificate, and the second is the "delta" or inner certificate. The extension contains only the differences between the base and delta certificates.

C. Construction of Hybrid Certificates Based on PQ/T

Considering the principles of certificate interoperability, the first is that all public keys included in the X.509 certificate can be extracted and used by another application; the second is that all signatures included in the X.509 certificate can be verified by programs from other vendors. After analyzing and comparing the five certificate formats, the hybrid certificate using extensions has advantages in terms of compatibility with standard X.509 certificates. Additionally, the certificate space is relatively small, and the technical implementation is relatively simple.

The construction of hybrid certificates using extensions is analyzed as follows. Three new X.509v3 extensions are added to the standard digital certificate to include the identifier, public key, and signature of the post-quantum algorithm. The specific ASN.1 syntax structure is shown in Figure 1.

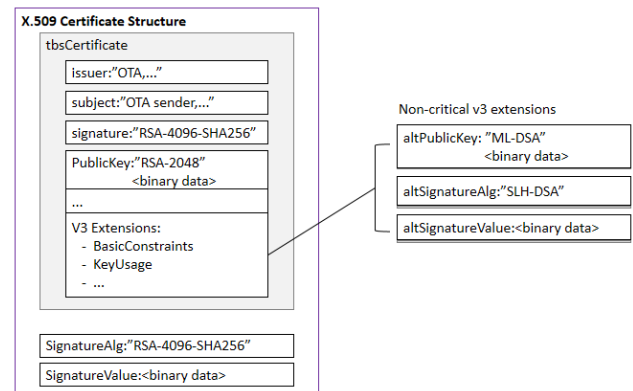


Figure 1. ASN.1 syntax structure of a certificate

- The Subject Alternative Public Key Information Extension, which contains the alternate public key and the algorithm used for the key, identified by the OID 'id-subjectAltPublicKeyInfo'.
- The Subject Alternative Signature Algorithm Extension, which contains the alternate digital signature algorithm identifier used by the CA to sign the 'preTBSCertificate', identified by the OID 'id-altSignatureAlgorithm'.
- The Alternative Signature Value Extension, which contains the digital signature computed on the ASN.1 DER-encoded 'preTBSCertificate', identified by the OID 'id-altSignatureValue'.

The process of signing the X.509v3 hybrid certificate using extensions is as follows:

- Create a 'PreTBSCertificate' object and populate all data to be signed by the alternate private key, including the 'SubjectAltPublicKeyInfoExt' and 'AltSignatureAlgorithmExt' extensions.
- Compute the PQC signature on the DER-encoded 'PreTBSCertificate' using the CA's PQC private key and the algorithm specified in the 'AltSignatureAlgorithmExt' extension.

- Add the computed PQC signature to the 'PreTBSCertificate' object using the 'AltSignatureValueExt' extension.
- Convert the 'PreTBSCertificate' to a 'TBSCertificate' by adding the signature field and populating it with the PKC algorithm and algorithm identifier used to sign the certificate.
- According to RFC 5280, compute the signature using the PKC private key associated with the CA and the certificate, and then create the certificate based on the 'tbsCertificate', 'signatureAlgorithm', and 'signature'.

The process of verifying the hybrid public key algorithm certificate is as follows:

- ASN.1 DER-decode the 'tbsCertificate' field of the certificate to obtain the 'TBSCertificate' object.
- Remove the 'AltSignatureValueExt' extension from the 'TBSCertificate' object, retaining the PQC signature.
- Remove the signature field from the 'TBSCertificate' object, converting it to a 'PreTBSCertificate' object.
- Verify the PQC signature using the algorithm specified in the 'AltSignatureAlgorithmExt' extension of the 'PreTBSCertificate', the PQC public key from the issuer's 'SubjectAltPublicKeyInfoExt' extension, and the ASN.1 DER-encoded 'PreTBSCertificate'.

D. Software Upgrade Security Design Based on PQ/T Public Key Infrastructure

The process and security scheme for implementing Over-The-Air (OTA) software upgrade protection using a Post-Quantum/Traditional (PQ/T) hybrid cryptography-based Public Key Infrastructure (PKI) are similar to those of classical PKI. Initially, we need to construct a PKI system that supports PQ/T hybrid certificates. Correspondingly, PQ/T hybrid digital certificates are issued for vehicles, the OTA cloud platform, and the OTA signing server.

The specific security design process for automotive software OTA upgrades is as follows:

- The OTA platform uses a PQ/T code signing certificate to sign the software upgrade package. This code signing is actually a dual signature: one is constructed using a classical signing algorithm such as RSA, ECDSA, or SM2; the other is constructed using a post-quantum algorithm such as SLH-DSA or ML-DSA.
- The vehicle and the OTA platform establish a secure TLS protocol supporting PQ/T algorithms for the transmission of the software upgrade package. In the future, when quantum computing becomes a reality, the TLS protocol can be upgraded to support Post-Quantum Cryptography (PQC).
- The vehicle uses the OTA platform's signing code certificate to verify the signature of the software upgrade package. For OTA signature verification, under current circumstances, only the signature of the

classical cryptographic algorithm needs to be verified. In the future, when quantum computing arrives, the post-quantum code signature will also be verified.

The greatest advantage of this security design is that it does not affect the current PKI security design scheme, and it provides an effective and necessary security method for the future quantum computing era. It can seamlessly transition to a future where PQC cryptographic applications are fully implemented.

V. CONCLUSIONS

By investigating the security threats that classical public-key cryptographic systems face under the conditions of future quantum computing, the proposed method based on PQ/T hybrid certificates not only ensures the security of automotive software upgrades in the present but also prepares for the era of quantum computing. Through a dual-signature strategy, post-quantum cryptographic algorithms can be introduced without sacrificing the compatibility and security of the existing PKI system, thereby achieving multiple protections for the integrity, confidentiality, authenticity, and non-repudiation of automotive software upgrade packages. The research presented in this paper not only provides a practical and feasible security upgrade solution for the automotive industry but also offers valuable references for other fields to address the challenges posed by quantum computing. As post-quantum cryptography continues to develop and become standardized, this study will play a key role in constructing a more secure network environment in the future.

REFERENCES

- [1] Shor, P. W., "Algorithms for quantum computation: discrete logarithms and factoring," in Proc. 35th Annu. Symp. Found. Comput. Sci., Santa Fe, NM, USA, 1994, pp. 124-134. doi: 10.1109/SFCS.1994.365700.
- [2] Grover, L. K., "A fast quantum mechanical algorithm for database search," in Proc. 28th Annu. ACM Symp. Theory Comput., Philadelphia, PA, USA, 1996, pp. 212-219. doi: 10.1145/237814.237866.
- [3] NIST, Module-Lattice-Based Key-Encapsulation Mechanism Standard, FIPS 203 (Initial Public Draft), Aug. 2024. [Online]. Available: <https://nvlpubs.nist.gov/nistpubs/FIPS/NIST.FIPS.203.ipd.pdf>.
- [4] NIST, Module-Lattice-Based Digital Signature Standard, FIPS 204 (Initial Public Draft), Aug. 2024. [Online]. Available: <https://nvlpubs.nist.gov/nistpubs/FIPS/NIST.FIPS.204.ipd.pdf>.
- [5] NIST, *Stateless Hash-Based Digital Signature Standard*, FIPS 205 (Initial Public Draft), Aug. 2024. [Online]. Available: <https://nvlpubs.nist.gov/nistpubs/FIPS/NIST.FIPS.205.ipd.pdf>.
- [6] NXP & NIST, "Deployment Guidelines for Post-Quantum PKI in Automotive OTA Systems," NISTIR 8485, 2025.
- [7] Yang Jiayu. Research and Application of Quantum-Resistant Cryptography[D]. Xi'an: Xidian University, 2021.
- [8] Bernstein D J, et al. The SPHINCS+ Signature Framework[C]. Proceedings of the 2019 ACM SIGSAC Conference on Computer and Communications Security (CCS 2019), ACM, 2019: 2129-2146.
- [9] Perazzo P, Bertoni G, Venturi M. Hardware Acceleration of Post-Quantum Signatures for Automotive FOTA Systems[J]. IEEE Transactions on Vehicular Technology, 2024, 73(5): 6231-6242.
- [10] Xu Y, Chen L, Wang Q. Blockchain-Based Post-Quantum Linkable Ring Signature for Anonymous Authentication in VANETs[J]. IEEE Transactions on Intelligent Transportation Systems, 2024, 25(3): 1892-1905.
- [11] Driscoll, F. and Prorock, M., Terminology for Post-Quantum Traditional Hybrid Schemes, IETF Internet-Draft draft-ietf-pquip-pqt-hybrid-

- terminology-02, Mar. 2025. [Online]. Available:
<https://datatracker.ietf.org/doc/draft-ietf-pquip-pqt-hybrid-terminology>
- [12] Ounsworth, M. et al., Composite ML-DSA for Use in Internet PKI, IETF Internet-Draft draft-ounsworth-pq-composite-sigs-13, Jan. 2025. [Online].